

01001001 01001110 01000101 • SYSTEM_OK • SEC_LEVEL_01

\$ CÓDIGO IEXPOSTOI >_

Guia Prático de Cibersegurança & Pentest em APIs



root@kernel:~# audit

```
>$ _ conhecimento é a melhor firewall.  
// Mapeamento automatizado de falhas lógicas e vetores de invasão
```

HACKER HUB

01. INVASÃO DE APIs: IDOR

> Insecure Direct Object References em Endpoints Modernos

O IDOR (Insecure Direct Object Reference) ocorre quando uma aplicação web ou API fornece acesso direto a objetos internos com base na entrada fornecida pelo usuário, sem validação prévia de autorização.

```
burp_suite // repeater_request.http

GET /api/v1/users/account/1042 HTTP/1.1
Host: target-empresa.com.br
Authorization: Bearer eyJhbGciOi... (Token do usuário 1041)

HTTP/1.1 200 OK
{ "user_id": 1042, "nome": "Diretor Financeiro", "saldo_pix": 85400.00 }
```

⚠ IMPACTO CRÍTICO (CVSS 8.6)

Uma falha lógica de IDOR permite que qualquer usuário autenticado acesse dados sensíveis de outros clientes, gerando vazamento em massa de dados protegidos pela LGPD.

Vetores de Detecção:

- Sequenciamento numérico de IDs
- Parâmetros em URLs e headers
- UUIDs previsíveis ou hashes MD5

Método de Remediação:

- Checagem rigorosa de sessão no backend
- Uso de GUIDs criptográficos
- Políticas de RBAC / ABAC